

RAPPORT DE TEST D'INTRUSION

TryHackMe — Basic Pentesting

Confidentiel — Ne pas diffuser

Auditeur	dimisan221
Cible	10.128.x.x / 10.129.x.x (THM)
Date	19 juin 2026
Classification	CONFIDENTIEL
Version	1.0

1. Résumé Exécutif

Ce rapport présente les résultats d'un test d'intrusion réalisé sur la machine TryHackMe "Basic Pentesting" dans le cadre d'un exercice pédagogique contrôlé. L'objectif était de simuler une attaque réaliste selon la méthodologie PTES (Penetration Testing Execution Standard) afin d'identifier les vulnérabilités exploitables sur le système cible.

L'évaluation a conduit à une compromission complète du système, incluant l'accès non autorisé aux données sensibles de l'utilisateur «kay» via une chaîne d'exploitation combinant : énumération de services, bruteforce SSH, escalade de privilèges horizontale par vol de clé SSH et cracking de passphrase.

Criticité	Nombre de vulnérabilités
Critique	1
Élevée	2
Moyenne	1
Faible	0

2. Périmètre et Contexte

2.1 Informations générales

Paramètre	Détail
Environnement	TryHackMe (lab isolé)
IP cible	10.128.x.x / 10.129.x.x (dynamique)
Type de test	Boîte noire (Black Box)
Autorisation	Oui — environnement CTF contrôlé
OS détecté	Ubuntu 20.04.6 LTS (Linux 5.15.0)
Durée	19 juin 2026

2.2 Objectifs

- Identifier les services exposés et les vecteurs d'entrée
- Obtenir un accès initial au système
- Escalader les privilèges pour accéder aux données de l'utilisateur «kay»
- Documenter chaque étape selon la méthodologie PTES

3. Méthodologie (PTES)

Le test a été conduit selon les 7 phases définies par le Penetration Testing Execution Standard (PTES) :

Phase PTES	Actions réalisées	Statut
1. Pré-engagement	Définition du périmètre, autorisation THM	✓ Complété
2. Collecte d'informations	Nmap, Gobuster, SMBClient, lecture fichiers	✓ Complété
3. Modélisation des menaces	Identification des utilisateurs jan/kay, services vulnérables	✓ Complété
4. Analyse des vulnérabilités	Mot de passe faible SSH, clé SSH lisible, passphrase crackable	✓ Complété
5. Exploitation	Bruteforce Hydra, pivot SSH avec clé volée	✓ Complété
6. Post-exploitation	Lecture de pass.bak, récupération credentials	✓ Complété
7. Rapport	Ce document	✓ Complété

4. Phase de Reconnaissance

4.1 Scan réseau — Nmap

Un scan TCP connect (-sT) avec détection d'hôte désactivée (-Pn) a été effectué pour cartographier les services exposés :

```
nmap -sT -Pn -T4 10.128.149.36
```

Port	État	Service	Remarque
22/tcp	Ouvert	SSH	Vecteur d'attaque principal
80/tcp	Ouvert	HTTP (Apache)	Site web en maintenance
139/tcp	Ouvert	NetBIOS-SSN	Transport SMB legacy
445/tcp	Ouvert	Microsoft-DS	SMB moderne
8009/tcp	Ouvert	AJP13	Connecteur Apache Tomcat
8080/tcp	Ouvert	HTTP-Proxy	Interface Tomcat

4.2 Énumération Web — Gobuster

Un fuzzing de répertoires a été lancé sur le serveur HTTP pour découvrir du contenu caché :

```
gobuster dir -u http://10.128.171.5:80 -w  
/usr/share/wordlists/dirb/common.txt
```

Résultat notable : le répertoire /development/ a été découvert (HTTP 301), exposant un index Apache sans authentification. Deux fichiers texte y étaient accessibles :

- dev.txt : révèle l'utilisation de Apache Struts 2.5.12 et la configuration SMB. Messages signés par «-K» et «-J»
- j.txt : confirmation que l'utilisateur J utilise un mot de passe faible facilement crackable depuis /etc/shadow

4.3 Énumération SMB — smbclient

Le partage SMB Anonymous a été accédé sans authentification :

```
smbclient //10.129.140.16/Anonymous -N
```

Le fichier staff.txt récupéré révèle deux noms d'utilisateurs valides : jan et kay. Ces informations ont directement alimenté la phase d'exploitation.

5. Vulnérabilités Identifiées

5.1 [CRITIQUE] Mot de passe SSH faible — Utilisateur jan

Attribut	Valeur
ID	VULN-001
Sévérité	CRITIQUE
CVSS v3 (estimé)	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Service affecté	SSH — Port 22/tcp
Utilisateur	jan
Mot de passe découvert	armando (présent dans rockyou.txt)

Description

L'utilisateur jan dispose d'un mot de passe extrêmement faible, présent dans les wordlists publiques les plus courantes. Un attaquant peut accéder au système via SSH en quelques minutes avec un outil de bruteforce standard.

Exploitation

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.128.183.54 -t 4
```

Résultat : mot de passe «armando» découvert.

Recommandations

- Appliquer une politique de mots de passe : minimum 12 caractères, majuscules, chiffres, caractères spéciaux
- Désactiver l'authentification par mot de passe SSH et n'autoriser que les clés cryptographiques
- Mettre en place un mécanisme de verrouillage de compte après N tentatives échouées (fail2ban)

5.2 [ÉLEVÉE] Clé SSH privée de kay accessible en lecture globale

Attribut	Valeur
ID	VULN-002
Sévérité	ÉLEVÉE
Permissions observées	-rw-r--r-- (644) — lisible par tous les utilisateurs
Fichier	/home/kay/.ssh/id_rsa

Description

La clé privée SSH de l'utilisateur kay présente des permissions incorrectes (644). Tout utilisateur local authentifié peut lire cette clé et tenter de s'en servir pour une connexion SSH.

Exploitation

```
cat /home/kay/.ssh/id_rsa # Depuis la session jan
ssh -i /tmp/kay_id_rsa kay@10.128.165.99
```

Recommandations

- Corriger immédiatement les permissions : `chmod 600 /home/kay/.ssh/id_rsa`
- Auditer régulièrement les permissions des fichiers sensibles avec `find / -name id_rsa -perm /044`
- Appliquer le principe du moindre privilège sur les répertoires home

5.3 [ÉLEVÉE] Passphrase de clé SSH crackable

Attribut	Valeur
ID	VULN-003
Sévérité	ÉLEVÉE
Outil	John the Ripper + rockyou.txt
Passphrase découverte	beeswax
Temps de crack	Moins de 1 minute

Description

Bien que la clé privée soit protégée par une passphrase, celle-ci est trop faible pour résister à une attaque par dictionnaire. Un attaquant ayant récupéré la clé peut l'utiliser rapidement.

Exploitation

```
ssh2john /tmp/kay_id_rsa > /tmp/kay_hash.txt
john /tmp/kay_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Résultat : passphrase «beeswax» trouvée.

Recommandations

- Utiliser une passphrase longue et aléatoire (minimum 20 caractères)
- Envisager l'utilisation d'un gestionnaire de mots de passe pour générer et stocker les passphrases

5.4 [MOYENNE] Divulgation d'informations via partage SMB anonyme

Attribut	Valeur
ID	VULN-004
Sévérité	MOYENNE
Service	SMB — Ports 139/445
Partage	Anonymous (accessible sans authentification)

Description

Le serveur expose un partage SMB accessible sans authentification contenant le fichier staff.txt, qui révèle les noms des utilisateurs du système. Cette information a directement permis de cibler l'attaque bruteforce.

Recommandations

- Désactiver les partages anonymes SMB si non nécessaires
- Ne jamais stocker d'informations sur les utilisateurs dans des partages accessibles sans auth
- Restreindre l'accès SMB aux seuls utilisateurs authentifiés et nécessaires

6. Chaîne d'Exploitation (Kill Chain)

L'attaque a suivi une chaîne logique en 6 étapes :

Étape	Action	Résultat
1	Scan Nmap + Gobuster	Services SSH, HTTP, SMB identifiés
2	SMBClient anonyme → staff.txt	Noms d'utilisateurs : jan, kay
3	Hydra bruteforce SSH → jan	Mot de passe : armando
4	Connexion SSH jan → lecture /home/kay/.ssh/id_rsa	Clé privée SSH de kay récupérée
5	John the Ripper → passphrase clé	Passphrase : beeswax
6	SSH avec clé kay → cat pass.bak	Credential final : heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$

7. Recommandations Prioritaires

Priorité	Action	Vulnérabilité ciblée
P1 — Immédiat	Désactiver auth SSH par mot de passe, imposer clés uniquement	VULN-001
P1 — Immédiat	Corriger permissions id_rsa : chmod 600	VULN-002
P2 — Court terme	Renouveler la clé SSH de kay avec passphrase forte	VULN-003
P2 — Court terme	Désactiver ou sécuriser le partage SMB anonyme	VULN-004
P3 — Moyen terme	Déployer fail2ban sur SSH	VULN-001
P3 — Moyen terme	Audit des permissions fichiers sensibles (tâche cron)	VULN-002
P3 — Moyen terme	Sensibilisation des utilisateurs aux mots de passe	Toutes

8. Conclusion

Ce test d'intrusion démontre qu'une combinaison de vulnérabilités de sévérité variable peut conduire à une compromission complète du système. Aucune des failles exploitées ne nécessite de compétences avancées : elles reposent toutes sur des erreurs de configuration basiques et le non-respect de politiques de sécurité élémentaires.

La surface d'attaque la plus critique réside dans la faiblesse des credentials SSH couplée à une mauvaise gestion des permissions de fichiers. La mise en oeuvre des recommandations P1 suffirait à bloquer la totalité de la chaîne d'exploitation documentée dans ce rapport.

Il est fortement recommandé de procéder à un nouveau test d'intrusion après application des correctifs afin de valider leur efficacité.